KEV + CVE ANALYSIS

Which Exploited Vulnerabilities Become Ransomware Targets?

ML analysis of CISA KEV + MITRE CVE

Rakitha Balasuiya

Index no.: [Index number]

Module: [Module] Date: [Presentation date]

https://github.com/Maverick-5/kev-ransomware-analysis

Why it matters

CVSS — How bad could the flaw be?

Defence — What will attackers use, and how soon?

KEV gives evidence of exploitation in the wild.

KEV is an observed catalogue, not a complete census of exploitation.

Two questions

Q1 / REGRESSION

Can CVE traits predict exploitation speed?

Proxy: publication-to-KEV-listing lag

Q2 / CLASSIFICATION

Which exploited CVEs are linked to ransomware?

Target: Known ransomware use in KEV

One dead end. One modest signal.

Dataset I built

CISA KEV joined to MITRE CVE records by CVE ID

1,694	39	283	2002–2026
records	raw columns	vendors	CVE ID years

Regression

exploitation_lag_days

KEV date added − CVE publication date

Classification

is_ransomware

20.8% Known ransomware links

Snapshot collected 03 Sep 2026. CVE ID year is not the publication-date range.

Cleaning and preprocessing

Retain uncertainty; remove explicit target-derived fields

Missing values

18.7% of CVSS vectors absent

Keep NOT_ASSESSED

→

Rare levels

Low-frequency categories

Collapse to OTHER

→

Feature set

Direct leakage fields excluded

64 encoded features

→

Evaluation

80/20 hold-out split

Seed 42

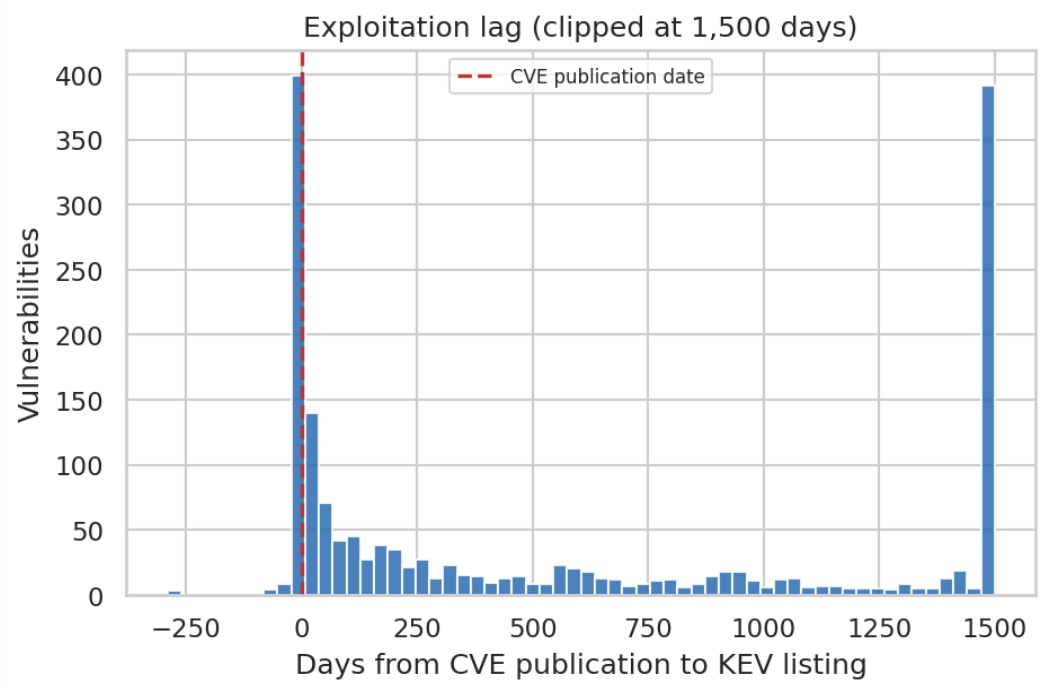
212 records listed on or before publication were retained.

Missingness varies with CVE age ($p < 0.001$).

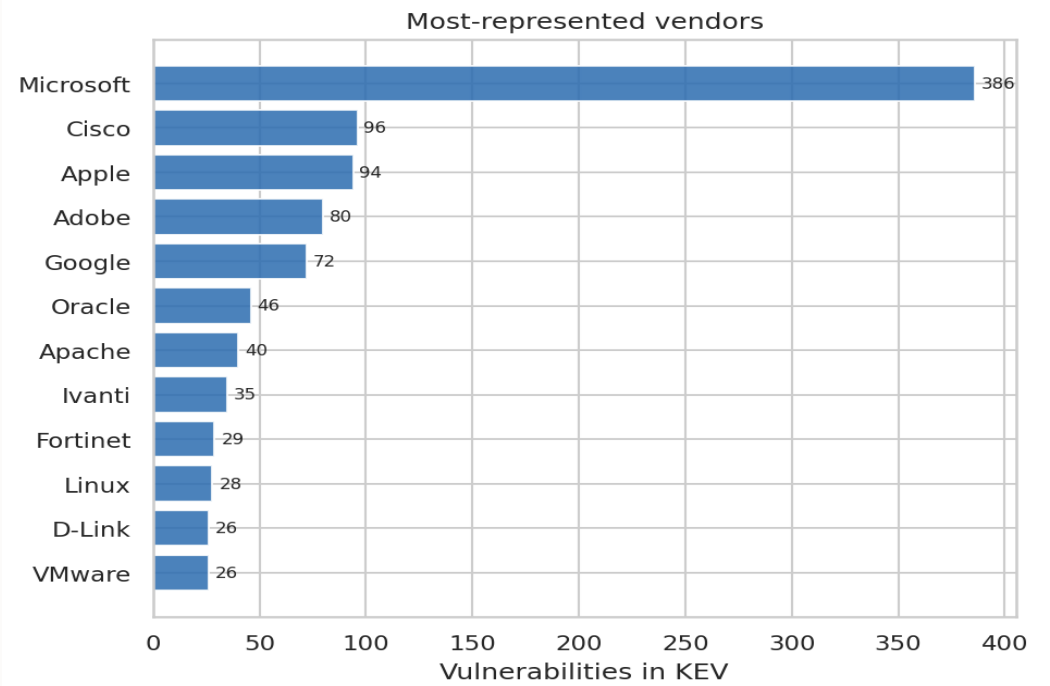
Validation limit: some preprocessing was fitted before splitting; refit within folds next.

What the data looks like

Quick listings coexist with a long publication-to-listing delay



782 listed more than a year later

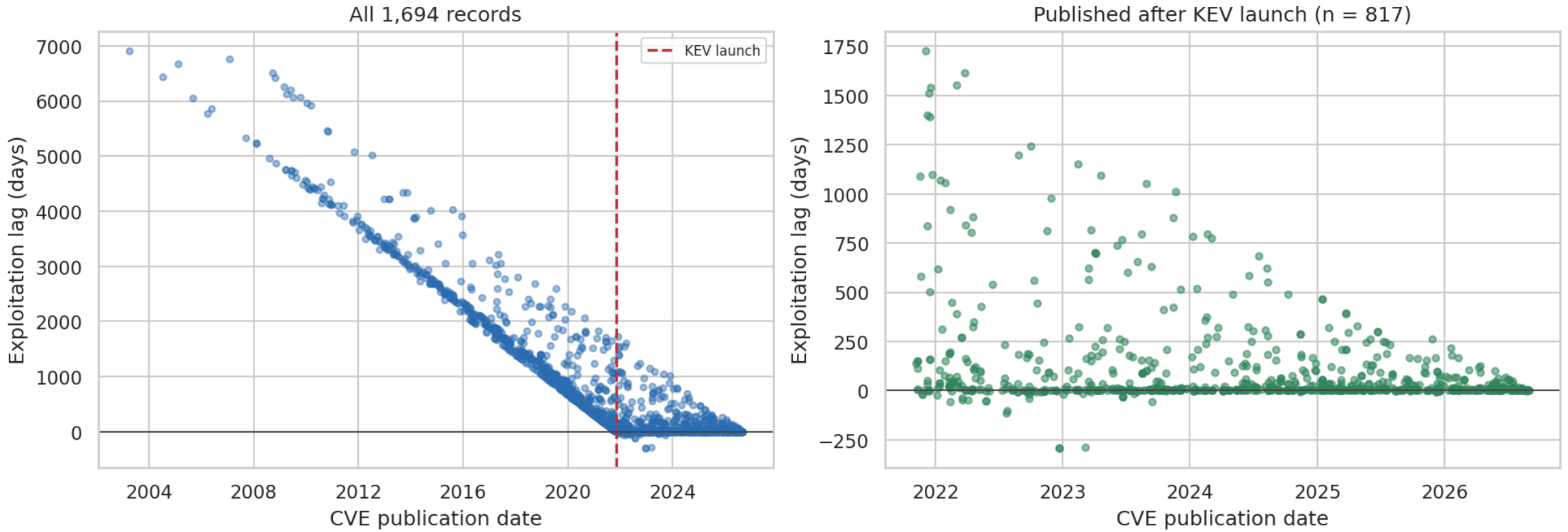


Microsoft: 22.8% of this catalogue

Selected panels: kfig1_lag, kfig5_who. Lag histogram capped at 1,500 days.

The trap: a calendar artefact

KEV opened in November 2021. Older CVEs inherit a large lag.



r = −0.916 → r = −0.293

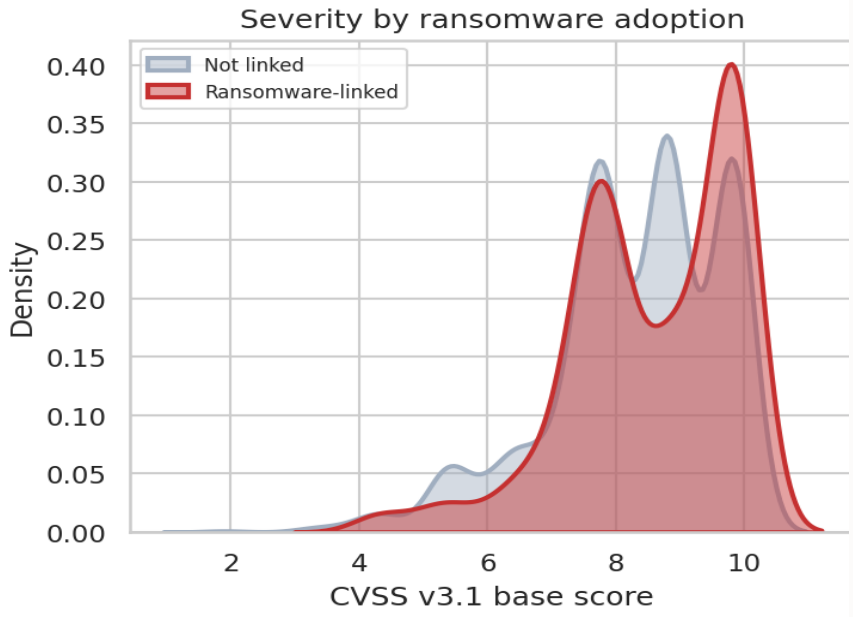
Right: only CVEs published on/after 03 Nov 2021 (n = 817). Lag means time to listing.

Significant does not mean useful

Small effects limit the practical value of the associations

Test	p-value	Effect
Welch t	0.00048	d = 0.21
Chi-square	0.000054	V = 0.098
Kruskal–Wallis	0.063	Not rejected

CVSS mean difference: 0.275 points

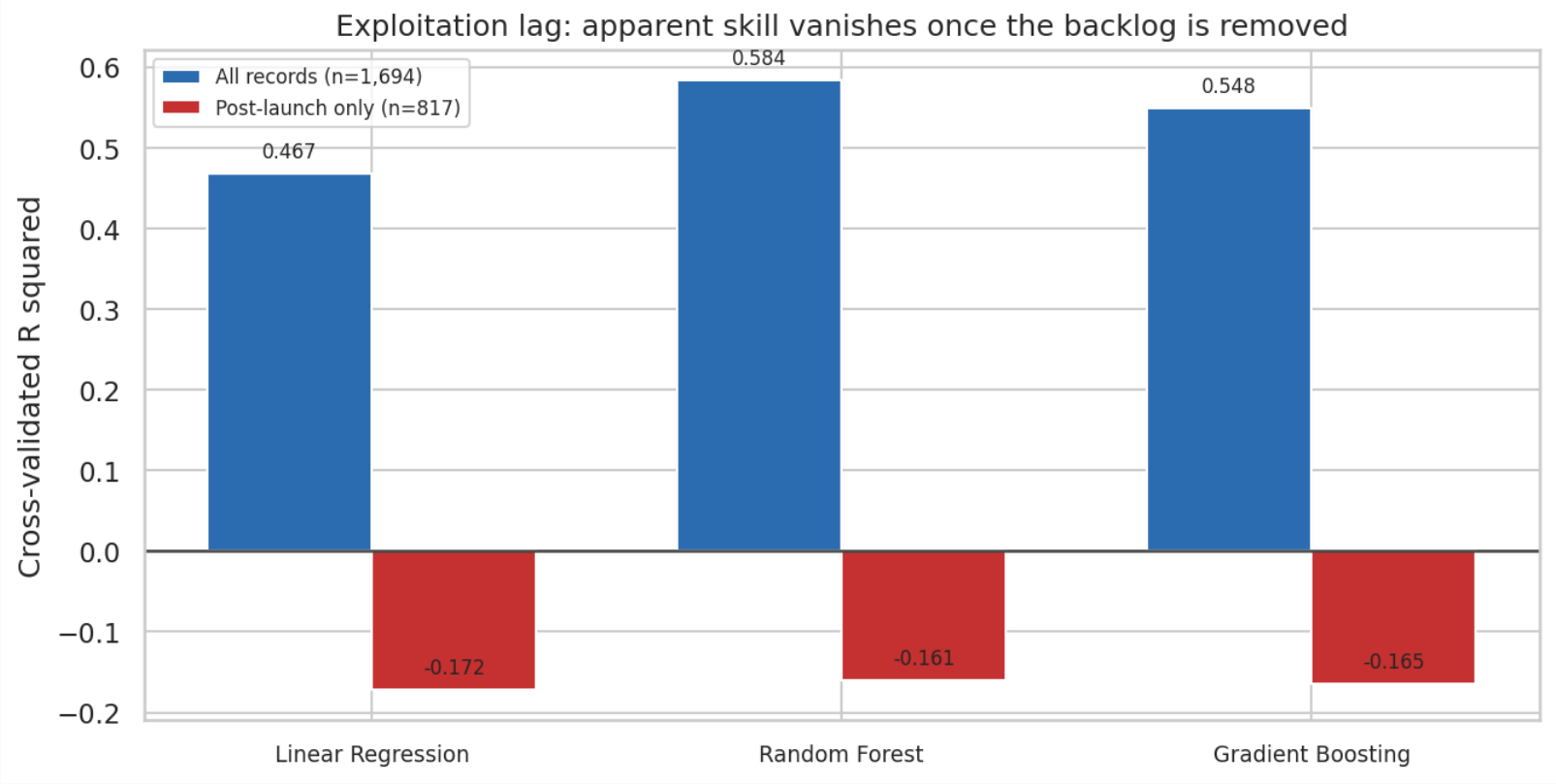


Strong overlap in severity

Automatable: 25.7% Known ransomware links vs 17.5%; odds ratio 1.64.

Q1: no useful speed prediction here

Apparent model skill collapses after the pre-launch backlog is removed



0.584

All records

↓

−0.161

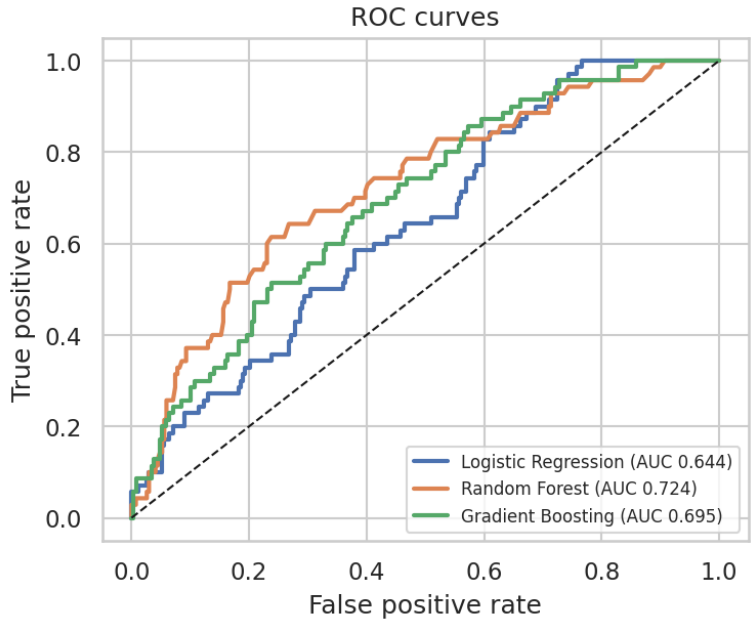
Post-launch only

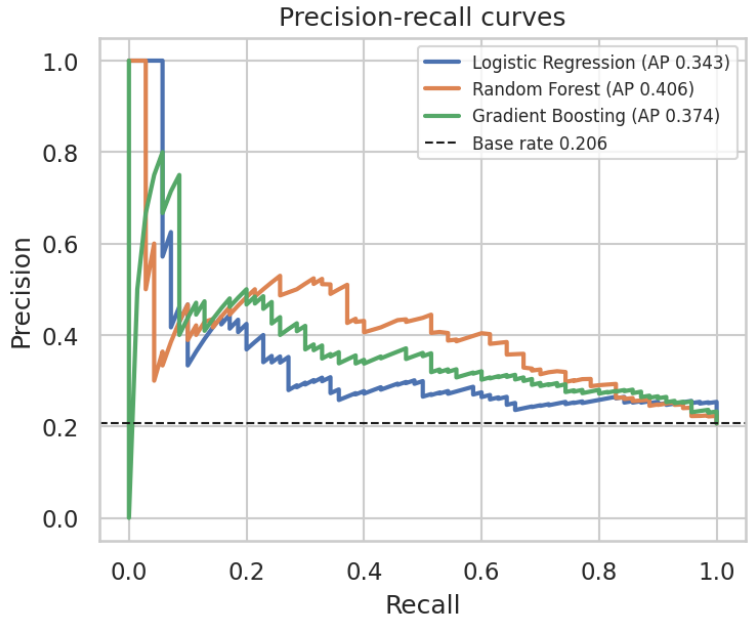
Random forest CV R^2. The target is log-transformed lag; zero is the mean benchmark.

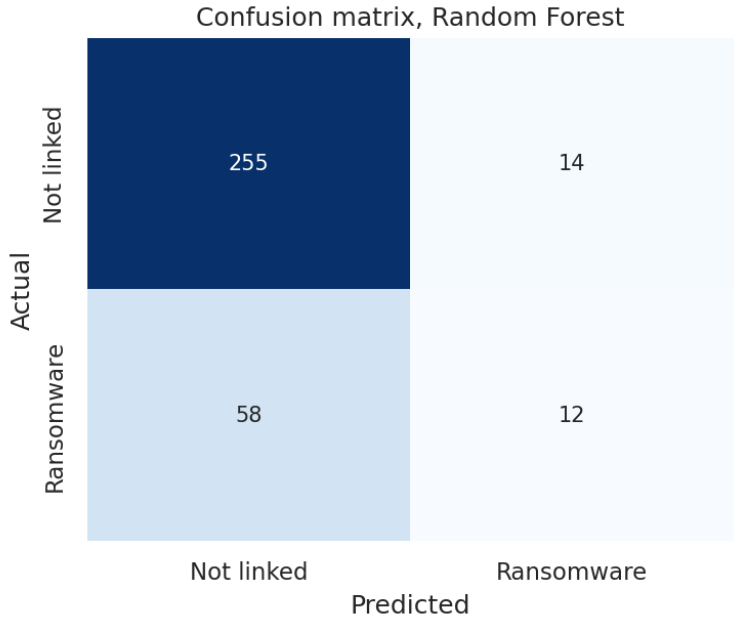
Q2: a modest ransomware signal

RF ROC-AUC 0.724

AP 0.406 vs 0.208 base rate



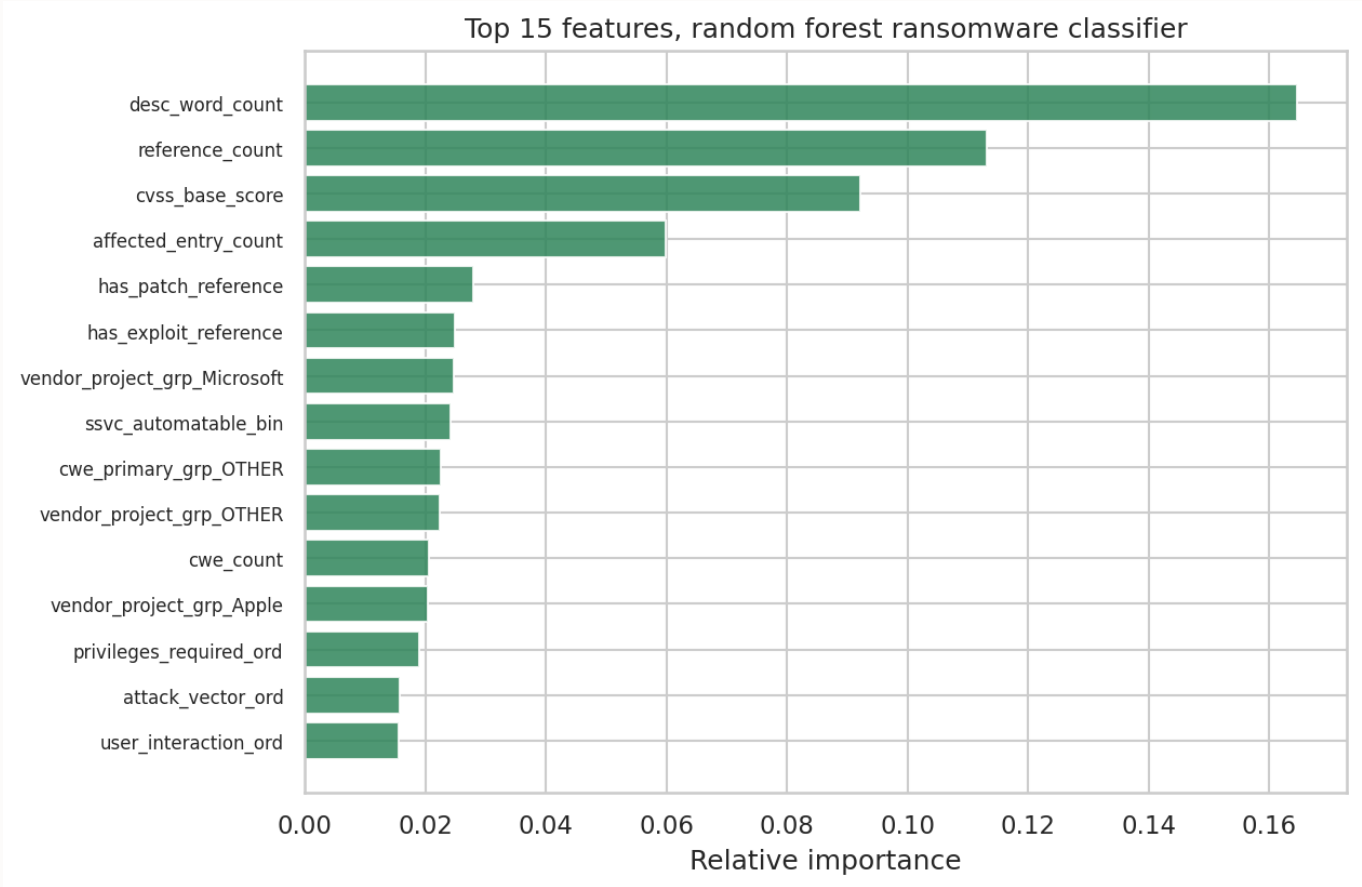




Model	ROC-AUC	Average precision	Recall at 0.5
Random forest	0.724	0.406	0.171
Logistic regression	0.644	0.343	0.600

RF accuracy 78.8% is below the 79.4% all-negative test-set baseline.

What drives the classifier



Description length
Reference count
CVSS score

Severity is not dominant.

These are associations, not causal drivers.

Impurity importance favours continuous features; snapshot metadata may post-date adoption.

Conclusions and limitations

What the evidence supports

CVSS ≠ attacker behaviour

Automatability adds a small signal

Consistent with considering
SSVC and EPSS alongside severity

What limits the claim

Exploited CVEs only
Unknown ransomware links
Censoring and detection bias
Metadata timing and preprocessing

Next: non-exploited CVEs + dated EPSS + temporal validation

SSVC and EPSS are relevant frameworks; neither was benchmarked in this study.

Questions / links

Two questions.
One dead end.
One modest signal.

Project repository

https://github.com/Maverick-5/kev-ransomware-analysis

CISA KEV ↗

MITRE / CVE records ↗

Seed 42 · pinned analysis packages

Retrospective snapshot. Python/Jupyter are not fully pinned; threshold metrics are version-sensitive.